Custodia: Aplicación de Escritorio para la Custodia Cifrada de Archivos con Control de Acceso Real sobre Windows

Dioyanny Yahaira Aranguren Sanabria
Programa de Ingeniería de Sistemas
Universidad Cooperativa de Colombia
Electiva Específica

Paula Alejandra Quintana Barrera
Programa de Ingeniería de Sistemas
Universidad Cooperativa de Colombia
Electiva Específica

***Resumen*—Este documento presenta el informe final del proyecto Custodia, una aplicación de escritorio para Windows que cifra en reposo los archivos que gestiona y delega la autorización de cada operación al sistema operativo mediante cuentas locales, listas de control de acceso (ACL) sobre NTFS y suplantación de identidad. El diseño parte de un análisis de riesgos con MAGERIT v3 sobre diez activos y dieciséis riesgos, del que se derivan veintiún controles organizados según los modelos AAA y CIA. La implementación, en Python con interfaz Qt Quick, incorpora además verificación en dos pasos (TOTP) para el ingreso y para toda operación sensible, bloqueo por intentos fallidos y por inactividad, y control de la exportación de copias. Se validó con 137 pruebas automatizadas ejecutadas sobre Windows real, de las cuales 136 pasan y una se omite; se cumplen seis de los ocho requisitos no funcionales medidos, y quedan pendientes la cobertura de pruebas, la prueba de usabilidad y el respaldo de la clave maestra. El documento incluye el marco teórico y legal, los diseños conceptual y lógico, la descripción de la implementación, el manual de usuario, los resultados y las recomendaciones.**

***Palabras clave*—análisis de riesgos, MAGERIT, cifrado en reposo, AES-256-GCM, control de acceso, NTFS, suplantación de identidad, TOTP, auditoría forense, AAA, CIA**

***Abstract*—This paper presents the final report of the Custodia project, a Windows desktop application that encrypts the files it manages at rest and delegates the authorization of every operation to the operating system through local accounts, NTFS access control lists (ACL) and identity impersonation. The design is based on a MAGERIT v3 risk analysis of ten assets and sixteen risks, from which twenty-one controls are derived and organized according to the AAA and CIA models. The implementation, written in Python with a Qt Quick interface, also adds two-step verification (TOTP) for login and for every sensitive operation, lockout after failed attempts and after inactivity, and control over exported copies. It was validated with 137 automated tests run on real Windows, of which 136 pass and one is skipped; six of the eight measured non-functional requirements are met, while test coverage, the usability test and the master key backup remain pending. The paper includes the theoretical and legal framework, the conceptual and logical designs, the implementation, the user manual, the results and the recommendations.**

***Index Terms*—risk analysis, MAGERIT, encryption at rest, AES-256-GCM, access control, NTFS, impersonation, TOTP, forensic auditing, AAA, CIA**

I. Resumen ejecutivo

Problema. En las aplicaciones que gestionan archivos, el control de acceso suele ser una regla escrita en su propio código, y el contenido se guarda en claro. Un error en esa regla falla en silencio, y cualquier acceso al disco por fuera de la aplicación expone la información.

Solución. Custodia no decide quién puede abrir un archivo: adopta la identidad del usuario y deja que el núcleo de Windows autorice o deniegue cada operación según los permisos NTFS. Además, cifra cada archivo con AES-256-GCM, exige un código TOTP para confirmar las operaciones sensibles y registra cada intento en una bitácora de auditoría.

Resultados.

- Aplicación completa con interfaz gráfica y ejecutable único para Windows (`Custodia.exe`).
- 137 pruebas automatizadas sobre Windows real: 136 pasan y una se omite. La prueba central demuestra que una denegación proviene del núcleo de Windows y no del código de la aplicación.
- Rendimiento holgado: 49,5 ms por operación de 10 MB (límite: 500 ms) y 14,8 ms de sobrecarga del cifrado (límite: 200 ms).
- Ningún riesgo crítico residual; el único crítico del análisis, que un usuario lea archivos de otro, baja de 16 a 4.

Pendientes. Respaldo de la clave maestra, cobertura de pruebas del núcleo (73 % frente al 80 % exigido), prueba de usabilidad y prueba del ejecutable en un equipo limpio.

II. Introducción y objetivos

II-A. Contexto

La confidencialidad de un archivo suele depender de dos supuestos frágiles: que la aplicación que lo gestiona evalúe correctamente quién puede abrirlo, y que nadie acceda al soporte donde está guardado por un camino distinto al previsto. Custodia aborda ambos. Cifra en reposo el contenido de cada archivo con AES-256 [1], de modo que un archivo obtenido por fuera de la aplicación sea ilegible. Y no decide por sí misma si una operación está permitida: cada usuario es una cuenta local real de Windows, cada carpeta tiene permisos NTFS reales [2] y cada operación se ejecuta con la identidad del usuario [3], de manera que es el sistema operativo quien la autoriza o la deniega.

II-B. Justificación

La seguridad informática se sostiene sobre principios que es fácil enunciar y difícil evidenciar en la práctica: confidencialidad, mínimo privilegio, autorización y trazabilidad [4]. Muchas aplicaciones los implementan como reglas propias, lo que duplica mecanismos que el sistema operativo ya ofrece, con menor garantía y sin posibilidad de verificación externa. El proyecto aplica esos principios con mecanismos reales y verificables: la confidencialidad, con un algoritmo de cifrado estándar y una gestión de claves explícita; la autorización, con las listas de control de acceso del sistema de archivos, comprobables con las mismas herramientas que usa un administrador (`icacls`, `net user`); y la trazabilidad, con un registro asociado a identidades autenticadas por el sistema operativo. El caso exige además recorrer el ciclo completo que propone el curso: identificar activos, analizar amenazas y riesgos con una metodología formal y derivar de ese análisis los controles.

II-C. Objetivos

Objetivo general. Desarrollar Custodia, una aplicación de escritorio para la protección confidencial de archivos mediante cifrado, con autorización de acceso basada en los mecanismos reales de seguridad de Windows.

Objetivos específicos.

1. Cifrar el contenido de los archivos almacenados mediante el algoritmo AES-256.
2. Delegar la autorización de acceso a los archivos en las cuentas locales y los permisos NTFS de Windows.
3. Registrar en una bitácora de auditoría las operaciones realizadas sobre los archivos.

II-D. Caso de estudio

El caso corresponde a la gestión documental interna de una dependencia u oficina en la que varias personas comparten un mismo equipo y un mismo repositorio de archivos, con distintos niveles de privilegio: usuarios estándar, que trabajan sobre sus propias carpetas y una carpeta común, y administradores, que gestionan cuentas y permisos sobre toda la estructura. El escenario se modela con cuentas locales de Windows agrupadas en `Custodia_Usuarios` y `Custodia_Administradores`, y con un almacén raíz sobre el que se aplican permisos NTFS diferenciados.

Cada necesidad del caso se traduce en requisitos concretos (Sección IV). Que varias personas compartan un equipo exige identidades separadas (RF-01, RF-02), que cada una opere solo sobre lo que le corresponde (RF-03, RF-04, RF-06, RF-07, RF-13) y que una sesión olvidada abierta no quede al alcance de cualquiera (RF-11). Que los documentos sean reservados exige que resulten ilegibles fuera de la aplicación (RF-08) y que sacar copias legibles quede controlado (RF-12). Y que la dependencia deba responder por lo ocurrido exige un registro de cada operación (RF-05), que es también la fuente de evidencia ante un incidente.

III. Marco conceptual y teórico

III-A. Principios de diseño seguro y control de acceso

Saltzer y Schroeder [4] formularon los principios que todavía orientan el diseño de mecanismos de protección. Tres de ellos sustentan este proyecto: el *mínimo privilegio*, según el cual cada sujeto opera con los permisos estrictamente necesarios; la *mediación completa*, que exige verificar la autorización en cada acceso a cada objeto; y la *economía de mecanismo*, que favorece diseños pequeños y verificables. El control de acceso es la mediación de toda solicitud de un sujeto sobre un objeto por parte de un monitor de referencia que consulta una política [5]. Lampson formalizó la protección como una matriz de acceso entre sujetos y objetos; cuando cada columna de esa matriz se guarda junto a su objeto, se obtiene una lista de control de acceso [6]. En el modelo discrecional (DAC), que es el de Windows, esa política se expresa como listas de control de acceso asociadas a cada objeto.

III-B. Modelo de seguridad de Windows

En Windows, el monitor de referencia de seguridad forma parte del núcleo del sistema operativo. Cada proceso e hilo porta un *token* de acceso con el identificador de seguridad (SID) del usuario y de sus grupos, y cada objeto asegurable tiene un descriptor de seguridad con una lista de control de acceso discrecional (DACL). Al abrir un objeto, el núcleo compara el *token* con las entradas de la DACL y concede o deniega el acceso [2], [7]. NTFS aplica este modelo a archivos y carpetas.

La *suplantación de identidad* (*impersonation*) permite que un hilo adopte temporalmente el *token* de otro usuario: la función `LogonUser` valida las credenciales y entrega el *token* [8], e `ImpersonateLoggedOnUser` lo asocia al hilo, de modo que toda operación posterior se autoriza como si la ejecutara ese usuario [3]. Custodia usa este mecanismo para que la mediación la ejerza el núcleo de Windows y no su propio código.

III-C. Cifrado simétrico y gestión de claves

AES es el algoritmo de cifrado simétrico por bloques estandarizado en FIPS 197 a partir del algoritmo Rijndael, con claves de 128, 192 o 256 bits [1], [9]. Para cifrar datos de longitud arbitraria se combina con un modo de operación; el modo GCM, especificado en NIST SP 800-38D, proporciona cifrado autenticado: garantiza a la vez la confidencialidad y la integridad del contenido, a condición de no repetir el vector de inicialización con una misma clave [10]. McGrew y Viega, sus autores, demostraron su seguridad bajo ese supuesto y mostraron que su rendimiento lo hace apto para cifrar a alta velocidad [11]. La clave se protege con la API de protección de datos de Windows (DPAPI), que la cifra con secretos administrados por el sistema operativo [12]. NIST SP 800-57 recomienda, además, prever copias de respaldo y procedimientos de recuperación para las claves de cuya pérdida dependa la disponibilidad de los datos [13].

Como alternativa a una clave única, el *cifrado de sobre* cifra cada archivo con una clave de datos propia y guarda esa

clave envuelta con la clave pública de cada persona autorizada, mediante RSA-OAEP [14]. La clave privada de cada persona se protege a su vez con una clave derivada de su contraseña mediante scrypt, una función de derivación diseñada para encarecer los ataques de fuerza bruta [15].

III-D. Autenticación de dos factores y fuerza bruta

Las contraseñas siguen siendo el mecanismo de autenticación dominante pese a sus debilidades conocidas frente al robo, la adivinación y la reutilización [16]. La autenticación multifactor las complementa combinando factores de naturaleza distinta, como algo que se sabe y algo que se tiene [17]. El algoritmo HOTP genera códigos de un solo uso a partir de un secreto compartido y un contador mediante HMAC [18]; TOTP sustituye el contador por el tiempo, de modo que el código cambia cada 30 segundos y puede calcularse en una aplicación del teléfono sin comunicación con el servidor [19]. NIST SP 800-63B exige que un verificador de códigos de un solo uso acepte cada código una sola vez y que limite la tasa de intentos fallidos para frenar los ataques de adivinación [20].

III-E. Modelos AAA y CIA

La tríada CIA (confidencialidad, integridad y disponibilidad) describe las propiedades de la información que se busca preservar [21]. El modelo AAA describe los servicios que las hacen posibles frente a los usuarios: autenticación (verificar la identidad), autorización (decidir qué puede hacer) y trazabilidad o *accounting* (registrar qué hizo). Ambos modelos organizan el diseño de controles de la Sección V-E.

III-F. Registros de auditoría y evidencia digital

NIST SP 800-92 establece que los registros de actividad son la base para detectar incidentes y reconstruir lo ocurrido, y que deben protegerse contra su alteración [22]. Desde la informática forense, NIST SP 800-86 describe el proceso de recolección, examen, análisis y reporte de evidencia [23], e ISO/IEC 27037 fija las pautas para identificar, recolectar y preservar evidencia digital de forma que conserve su valor probatorio [24]. Schneier y Kelsey propusieron encadenar criptográficamente los registros de auditoría, de modo que un atacante que tome el control del equipo no pueda alterar ni borrar los registros anteriores sin que se note [25]. Garfinkel, por su parte, señala el cifrado generalizado como uno de los obstáculos crecientes del análisis forense [26]: cuando el contenido está cifrado, los registros de actividad ganan peso como evidencia.

III-G. Gestión de riesgos

MAGERIT v3 es la metodología de análisis y gestión de riesgos de la administración pública española [27]. Parte de los activos y su valor, identifica las amenazas que pueden degradarlos, estima impacto y riesgo, y selecciona salvaguardas; su catálogo de elementos tipifica activos, dimensiones y amenazas [28]. Es compatible con el proceso de gestión de riesgos de ISO/IEC 27005 [29].

III-H. Marco legal

Ley 1581 de 2012 [30]. Regula la protección de datos personales en Colombia. Su principio de seguridad (artículo 4, literal g) obliga a manejar la información con las medidas técnicas, humanas y administrativas necesarias para evitar su adulteración, pérdida, consulta, uso o acceso no autorizado. El proyecto usa exclusivamente archivos y cuentas de prueba creados por las autoras, sin datos personales de terceros. Si Custodia se desplegara en una dependencia real, los archivos custodiados podrían contener datos personales o sensibles; en ese caso la organización actuaría como responsable del tratamiento, y los controles de cifrado, autorización y auditoría de Custodia harían parte de las medidas técnicas que exige dicho principio. La bitácora almacena nombres de cuenta y de recurso, y el motivo de cada copia exportada, por lo que también quedaría sujeta a la ley.

Ley 1273 de 2009 [31]. Tipifica los delitos informáticos, entre ellos el acceso abusivo a un sistema informático (artículo 269A), el daño informático (269D) y la violación de datos personales (269F). Custodia es una herramienta defensiva y no incorpora capacidad ofensiva. Las pruebas de los vectores de ataque (Sección V-C) se ejecutaron únicamente sobre equipos y cuentas de prueba de las autoras, por lo que no configuran ninguna de esas conductas.

IV. Requisitos funcionales y no funcionales

Las Tablas I y II presentan los requisitos. Los requisitos RF-01 a RF-08 y RNF-01 a RNF-08 se levantaron en el Hito 1. Los requisitos RF-09 a RF-13 se incorporaron durante la implementación, como respuesta a riesgos identificados en el análisis (Sección V-D): sin ellos, una contraseña robada o una sesión desatendida bastaban para operar sobre los archivos. Su verificación se presenta en la Sección IX.

IV-A. Alcance

El proyecto cubre el diseño y la implementación de un núcleo en Python que gestiona cuentas y grupos locales de Windows, permisos NTFS sobre un almacén controlado, suplantación de identidad, cifrado en reposo, verificación en dos pasos y bitácora de auditoría en SQLite [33], junto con una interfaz de escritorio nativa en PySide6 [34], su empaquetado con PyInstaller [35] y el análisis de riesgos que sustenta sus controles.

IV-B. Limitaciones

- Funciona únicamente sobre Windows y NTFS, por depender de su API de seguridad.
- Las cuentas y grupos son locales; no se integra con un dominio de Active Directory.
- Es una aplicación local: no expone servicios de red ni admite acceso remoto concurrente.
- No protege frente a un atacante que ya ejecuta código con privilegios de administrador en el equipo (Sección V-D).
- La administración de cuentas es la única autorización que decide la aplicación y no Windows: crear una cuenta exige que el proceso esté elevado, sea quien sea el que inició sesión (Sección VI).

Tabla I
REQUISITOS FUNCIONALES

ID	Requisito
RF-01	Crear cuentas de usuario locales de Windows desde la aplicación.
RF-02	Asignar cada usuario a uno de los dos grupos de Custodia.
RF-03	Crear, leer, renombrar y eliminar archivos y carpetas solo cuando el usuario tenga el permiso NTFS correspondiente.
RF-04	Rechazar toda ruta que, una vez resuelta, quede fuera del almacén.
RF-05	Registrar en la bitácora cada operación intentada, con usuario, fecha y hora, recurso y resultado.
RF-06	Modificar los permisos NTFS de un recurso desde la interfaz.
RF-07	Mostrar el propietario y los permisos efectivos del usuario autenticado sobre cada recurso.
RF-08	Cifrar el contenido de cada archivo antes de guardarlo y descifrarlo solo tras la autenticación y la verificación de permisos.
RF-09*	Exigir un código TOTP en el ingreso, si la cuenta lo tiene activado, y en toda operación sensible sobre archivos, permisos o cuentas; cada código vale una sola vez.
RF-10*	Bloquear una cuenta durante 15 minutos tras 5 intentos fallidos en 10 minutos, contando contraseñas y códigos incorrectos.
RF-11*	Bloquear la interfaz tras 5 minutos sin actividad y cerrar la sesión si sigue bloqueada 30 minutos más.
RF-12*	Exigir un motivo y un código TOTP para exportar una copia legible de un archivo, y limitar las copias a 20 cada 10 minutos por usuario.
RF-13*	Dar a cada usuario un espacio personal exclusivo y una carpeta compartida con su grupo, sin que pueda listar ni crear contenido en la raíz del almacén.

* Incorporados durante la implementación.

Tabla II
REQUISITOS NO FUNCIONALES

ID	Requisito y criterio de aceptación
RNF-01	Seguridad: toda suplantación se revierte; cero suplantaciones remanentes tras 100 operaciones consecutivas.
RNF-02	Rendimiento: una operación sobre un archivo de hasta 10 MB tarda como máximo 500 ms en promedio.
RNF-03	Portabilidad del núcleo: contrato único de permisos con implementaciones intercambiables; las mismas pruebas pasan contra todas.
RNF-04	Usabilidad: crear una carpeta y verificar sus permisos en no más de 3 pasos, comprobado con dos personas ajenas al desarrollo.
RNF-05	Confiabilidad: ninguna operación denegada deja archivos parciales o huérfanos.
RNF-06	Mantenibilidad: cobertura de pruebas del núcleo no inferior al 80 %, medida con `pytest-cov` [32].
RNF-07	Entrega: ejecutable único de Windows, sin navegador ni servidor local, que funcione en un equipo sin Python.
RNF-08	Cifrado: AES-256, sobrecarga máxima de 200 ms sobre 10 MB y clave nunca en texto plano.

V. DISEÑOS CONCEPTUAL Y LÓGICO

El diseño se construyó en cuatro pasos: inventario de activos, identificación de amenazas y vectores de ataque, análisis de riesgos y derivación de controles. Los diagramas conceptual y lógico (Figs. 1 y 2) muestran cómo esos controles se ubican en la arquitectura.

V-A. Inventario y clasificación de activos

Los activos se identificaron recorriendo el flujo de una operación sobre un archivo (autenticación, autorización, lectura o escritura cifrada y registro) y se clasificaron según los tipos del catálogo de MAGERIT v3 [28]. Cada activo se valoró de 1 (muy bajo) a 5 (muy alto) en las cinco dimensiones de MAGERIT: disponibilidad (D), integridad (I), confidencialidad (C), autenticidad (A) y trazabilidad (T). La Tabla III presenta el resultado.

Tabla III
INVENTARIO, CLASIFICACIÓN Y VALORACIÓN DE ACTIVOS

ID	Activo	Tipo	D	I	C	A	T
A01	Archivos de los usuarios (cifrados en el almacén)	[D]	4	5	5	4	4
A02	Clave maestra y secretos de autenticación (`master.key`, `2fa.dat`)	[K]	5	5	5	4	3
A03	Bitácora de auditoría (`audit.db`)	[D]	3	5	3	4	5
A04	Credenciales de las cuentas locales (SAM)	[D]	4	5	5	5	4
A05	ACL de NTFS y grupos locales de Custodia	[D]	4	5	2	4	4
A06	Aplicación Custodia (núcleo e interfaz)	[SW]	4	5	2	4	3
A07	Windows y sus servicios de seguridad (LSA, NTFS, DPAPI)	[SW]	5	5	3	5	4
A08	Equipo anfitrión y su disco	[HW]	4	3	4	2	2
A09	Servicio de gestión documental de la dependencia	[S]	4	4	4	4	4
A10	Usuarios y administradores	[P]	3	3	3	4	3

Los activos esenciales son A01 y A09: la información de la dependencia y el servicio que la pone a disposición de quien tiene derecho a ella. Los demás son activos de soporte. La dependencia más crítica es la de A01 sobre A02: quien obtiene la clave maestra anula la confidencialidad de todos los archivos, y quien la destruye anula su disponibilidad.

V-B. Amenazas y vulnerabilidades

Las amenazas se tomaron del catálogo de MAGERIT v3 [28], que las agrupa por origen: desastres naturales [N], origen industrial [I], errores y fallos no intencionados [E] y ataques intencionados [A]. Dado que el caso es una aplicación local sin servicio de red, se descartaron las amenazas de comunicaciones y se conservaron las de la Tabla IV, cada una asociada a la vulnerabilidad que la haría posible en ausencia de controles.

V-C. Vectores de ataque y metodología de análisis

Los vectores se identificaron en tres pasos. Primero se trazó el flujo de datos de la aplicación y sus fronteras de confianza: entre el usuario y la interfaz, entre la aplicación y el sistema operativo, y entre el sistema operativo y el disco. Segundo, en cada frontera se aplicó STRIDE [36] (suplantación, manipulación, repudio, divulgación, denegación de servicio y elevación de privilegios) para enumerar de forma sistemática qué puede salir mal. Tercero, cada vector se relacionó con una técnica

Tabla IV
AMENAZAS (MAGERIT) Y VULNERABILIDADES ASOCIADAS

Amenaza	Activos	Vulnerabilidad
[A.11] Acceso no autorizado	A01, A05	Autorización decidida por la lógica de la aplicación; ACL permisivas o heredadas; sesión abierta y desatendida.
[A.5] Suplantación de identidad	A04, A10	Contraseñas débiles o robadas; ausencia de bloqueo por intentos fallidos; un solo factor.
[A.6] Abuso de privilegios	A01, A02, A06	La aplicación se ejecuta elevada; una suplantación no revertida deja un hilo con otra identidad.
[A.19] Divulgación de información	A01, A02	Archivos legibles fuera de Windows; clave almacenada junto a los datos; exportación de copias sin control.
[A.25] Robo de equipos o soportes	A08, A01	Disco sin cifrado de volumen; equipo sin protección física.
[A.15] Modificación deliberada	A01, A05	Contenido sin verificación de integridad.
[A.3] Manipulación de registros de actividad	A03	Bitácora en un archivo local modificable por cuentas privilegiadas.
[A.13] Repudio	A03, A09	Operaciones no atribuibles a una identidad verificada.
[E.20] Vulnerabilidades de los programas	A06	Rutas no validadas (*path traversal*); dependencias de terceros.
[E.1], [E.2] Errores de usuarios y del administrador	A05, A01	Asignación manual de permisos sin retroalimentación sobre el efecto real.
[E.18] Destrucción de información	A02, A01	Clave maestra única y sin copia de respaldo.
[I.5] Avería de origen físico o lógico	A01, A08	Escrituras interrumpidas que dejan archivos parciales.

de MITRE ATT&CK [37] o una debilidad de CWE [38], lo que permite contrastarlo con comportamiento documentado de atacantes reales, y con la amenaza MAGERIT correspondiente, que es la entrada del análisis de riesgos.

La Tabla V resume los vectores. Se consideran cuatro perfiles de atacante: un usuario legítimo que intenta exceder sus permisos, una persona que encuentra una sesión abierta, un atacante con acceso físico al equipo o al disco, y un proceso malicioso que se ejecuta en la misma máquina. Los vectores V11 y V12 se añadieron durante la implementación.

V-D. Análisis de riesgos

Metodología. Se aplicó MAGERIT v3 [27] en su forma cualitativa. MAGERIT estima el impacto como el valor del activo afectado por la degradación que le causa la amenaza, y el riesgo como la combinación de ese impacto con la probabilidad de ocurrencia. Se usaron escalas de cinco niveles:

- **Probabilidad (P):** 1 muy baja, 2 baja, 3 media, 4 alta, 5 muy alta.
- **Impacto (I):** valor del activo en la dimensión afectada, ajustado por la degradación esperada; de 1 (muy bajo) a 5 (muy alto).
- **Riesgo:** $R = P \times I$. Bajo de 1 a 4, medio de 5 a 9, alto de 10 a 15 y crítico de 16 a 25.

Cada riesgo se evaluó dos veces: el riesgo *potencial*, suponiendo una aplicación que gestiona archivos sin las salvaguardas de Custodia, y el riesgo *residual*, con los controles efectivamente implementados en la versión final. Un control planificado que no se implementó no reduce el riesgo residual.

Tabla V
VECTORES DE ATAQUE RELEVANTES

ID	Vector	STRIDE	Referencia
V1	Adivinación o fuerza bruta de contraseñas en el ingreso	S	ATT&CK T1110
V2	Ruta manipulada (`..\`) para salir del almacén	E, I	CWE-22
V3	Operación sobre recursos ajenos desde una sesión válida	E, I	ATT&CK T1078
V4	Aprovechamiento de una suplantación no revertida	E	ATT&CK T1134
V5	Lectura del disco desde otro sistema operativo o tras su robo	I	ATT&CK T1005
V6	Extracción de la clave maestra por un proceso local	I	ATT&CK T1555
V7	Alteración de archivos cifrados directamente en disco	T	ATT&CK T1565
V8	Borrado o edición de la bitácora	T, R	ATT&CK T1070
V9	Destrucción de la clave maestra o del almacén	D	ATT&CK T1485
V10	Código malicioso cargado por el ejecutable elevado	E	ATT&CK T1068
V11	Uso de una sesión abierta y desatendida	S, E	CWE-613
V12	Exportación masiva de copias legibles	I	ATT&CK T1052

Matriz y mapas de calor. La Tabla VI presenta la matriz; las columnas P, I y R corresponden al riesgo potencial, y P', I' y R' al residual. Las Tablas VII y VIII ubican los dieciséis riesgos antes y después de los controles. R15 y R16 se identificaron durante la implementación y motivaron los requisitos RF-11 y RF-12.

Hallazgos.

- **Del riesgo potencial al residual.** De los dieciséis riesgos, uno era crítico (R2), once altos y cuatro medios. Con los controles implementados no queda ninguno crítico: tres permanecen altos, siete quedan en nivel medio y seis en nivel bajo.
- **El único riesgo crítico es el que motiva el proyecto.** R2 baja de 16 a 4 porque la decisión de autorizar deja de depender del código de la aplicación.
- **El segundo factor fue el control de mayor efecto añadido en la implementación.** Reduce a nivel bajo el ingreso con credenciales robadas (R4) y el uso de una sesión desatendida (R15), y hace atribuible cada operación sensible (R12).
- **El cifrado de archivos no basta frente al robo del disco completo (R1).** DPAPI en ámbito de máquina protege la clave con secretos que residen en el mismo disco. Un atacante que solo obtiene los archivos del almacén no puede leerlos, pero uno con el disco completo y conocimientos avanzados podría reconstruir la clave. El control compensatorio es el cifrado de volumen (BitLocker con

Tabla VI
MATRIZ DE RIESGOS: RIESGO POTENCIAL Y RIESGO RESIDUAL CON LOS CONTROLES IMPLEMENTADOS

ID	Riesgo	Amenaza	Activo	P	I	R	Salvaguarda	P'	I'	R'
R1	Lectura de los archivos tras el robo del disco o el arranque de otro sistema operativo	A.25, A.19	A01, A08	3	5	15	Cifrado AES-256-GCM de cada archivo; clave protegida con DPAPI. Cifrado de volumen recomendado como control compensatorio.	2	5	10
R2	Un usuario accede a archivos de otro desde la aplicación	A.11	A01	4	4	16	Operación ejecutada bajo suplantación; decide la ACL de NTFS, no la aplicación; espacios personales con herencia rota.	1	4	4
R3	Acceso a rutas fuera del almacén	E.20	A01, A07	3	5	15	Confinamiento: toda ruta se resuelve y se rechaza si queda fuera de la raíz (RF-04).	1	5	5
R4	Ingreso con credenciales adivinadas o robadas	A.5	A04	3	4	12	Autenticación delegada a Windows; bloqueo tras 5 intentos fallidos; segundo factor TOTP.	1	4	4
R5	Operaciones ejecutadas con una identidad suplantada remanente	A.6	A06, A01	2	5	10	Reversión obligatoria en bloque `finally`; suplantación concentrada en una sola clase; prueba de cero suplantaciones remanentes (RNF-01).	1	5	5
R6	Extracción de la clave maestra por un proceso local	A.6, A.19	A02	3	5	15	Blob DPAPI con entropía propia; ACL del archivo limitada a Administradores y SYSTEM; clave solo en memoria.	2	5	10
R7	Alteración o borrado de la bitácora	A.3	A03	3	4	12	Bitácora escrita por un hilo que nunca suplanta; ACL que excluye a los usuarios estándar.	2	4	8
R8	Modificación de un archivo cifrado en disco	A.15	A01	2	4	8	Etiqueta de autenticación GCM: la alteración se detecta y el archivo se rechaza.	2	2	4
R9	Pérdida o corrupción de la clave maestra	E.18	A02, A01	2	5	10	Respaldo de la clave (C13): **no implementado**; el riesgo se mantiene.	2	5	10
R10	Abuso de privilegios por un administrador de Custodia	A.6	A01, A05	2	4	8	Separación en dos grupos; código TOTP y registro en bitácora de toda operación administrativa.	2	3	6
R11	Permisos mal asignados por error	E.1, E.2	A05	4	3	12	Panel de permisos efectivos (RF-07); permisos iniciales restrictivos (RF-13).	2	3	6
R12	Un usuario niega haber realizado una operación	A.13	A03, A09	3	3	9	Bitácora asociada a la cuenta real de Windows autenticada y al código TOTP de confirmación.	1	3	3
R13	Archivo parcial o corrupto por una escritura interrumpida o denegada	I.5	A01	3	3	9	Escritura atómica: archivo temporal y renombrado final (RNF-05).	1	3	3
R14	Código malicioso ejecutado con los privilegios de la aplicación	E.20	A06, A07	2	5	10	Sin servicio de red ni servidor local; dependencias con versión mínima fijada; ejecutable único.	2	4	8
R15	Uso de una sesión abierta y desatendida	A.11, A.5	A01, A05	3	4	12	Bloqueo por inactividad y cierre de sesión; código TOTP en cada operación sensible.	1	4	4
R16	Fuga de información mediante copias legibles exportadas	A.19	A01	3	5	15	Motivo obligatorio en bitácora; código TOTP; límite de 20 copias cada 10 minutos.	2	4	8

Tabla VII
MAPA DE CALOR DEL RIESGO POTENCIAL

I \ P	1	2	3	4	5
5		R5, R9, R14	R1, R3, R6, R16		
4		R8, R10	R4, R7, R15	R2	
3			R12, R13	R11	
2					
1					

Bajo (1–4) | Medio (5–9) | Alto (10–15) | Crítico (16–25)

Tabla VIII
MAPA DE CALOR DEL RIESGO RESIDUAL

I \ P	1	2	3	4	5
5	R3, R5	R1, R6, R9			
4	R2, R4, R15	R7, R14, R16			
3	R12, R13	R10, R11			
2		R8			
1					

Bajo (1–4) | Medio (5–9) | Alto (10–15) | Crítico (16–25)

TPM).

- **Un proceso con privilegios de administrador puede obtener la clave (R6).** Es una limitación inherente a un diseño local y se declara como riesgo residual aceptado. El cifrado por usuario (C20) lo reduciría, pero está desactivado por defecto.
- **La clave maestra sigue siendo un punto único de fallo (R9).** El respaldo de la clave no se implementó, por lo que este riesgo conserva su nivel alto y es la primera recomendación de este informe.

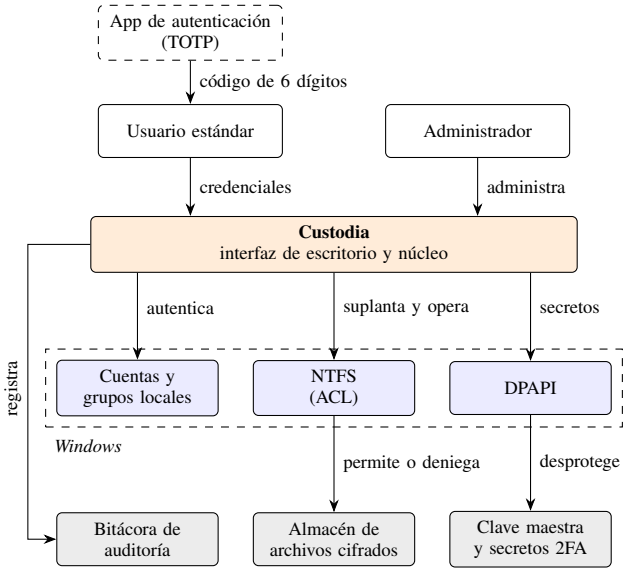


Figura 1. Diagrama conceptual de Custodia.

V-E. Diseño lógico de los controles (AAA y CIA)

Los controles se organizan según los dos modelos solicitados. El modelo AAA responde a quién es el usuario (C1, C2, C17, C18), qué puede hacer (C3 a C6, C21) y qué hizo (C7); la tríada CIA responde a qué propiedades de la información se protegen: confidencialidad (C8, C9, C15, C19, C20), integridad (C10, C11, C12, C16) y disponibilidad (C13, C14). La Tabla IX presenta cada control, su mecanismo, los riesgos que trata y su estado en la versión final.

Los controles C3 y C8 son deliberadamente independientes. La ACL protege mientras Windows está en ejecución y media el acceso; el cifrado protege cuando esa mediación deja de existir. Que cada uno cubra el punto donde el otro no actúa es la aplicación del principio de defensa en profundidad al caso.

V-F. Diagrama conceptual

La Fig. 1 muestra los actores, el sistema y los servicios de Windows en los que se apoya. La idea central es que Custodia no decide: solicita a Windows que autentique, ejecuta cada operación con la identidad del usuario y deja que NTFS la permita o la deniegue. El teléfono del usuario aporta el segundo factor sin comunicarse con la aplicación.

V-G. Diagrama lógico

La Fig. 2 detalla la arquitectura en cinco capas. La interfaz nunca invoca la API de Windows directamente ni suplanta identidades: lo hace a través de la clase `Sesion`, la frontera con el núcleo. Esta decisión no es estética: la suplantación en Windows es por hilo y hay que revertirla siempre, y si cada botón la gestionara por su cuenta, bastaría un retorno anticipado en un solo manejador para dejar el hilo de la interfaz con la identidad de otro usuario. El núcleo se divide en módulos de identidad (fila superior) y de archivos (fila inferior), y es el único que habla con Windows.

V-H. Flujo de una operación

La exportación de una copia (“Guardar una copia”) es la operación que más controles recorre:

1. Al arrancar, con su identidad privilegiada, la aplicación carga la clave maestra en memoria e inicia la bitácora (C9, C14).
2. El usuario ingresa su contraseña y su código TOTP; Windows valida la contraseña y la aplicación el código (C1, C2, C17).
3. El usuario elige un archivo; se comprueba que no haya superado el límite de copias y se le pide el motivo (C19).
4. Se pide un código TOTP nuevo; un código ya usado se rechaza (C17).
5. La ruta se resuelve y se confina al almacén (C5); el hilo adopta la identidad del usuario y abre el archivo, y NTFS permite o deniega (C3).
6. Si se permitió, el contenido se descifra y se verifica su etiqueta de autenticación (C8, C10).
7. El hilo recupera su identidad original, sea cual sea el resultado (C6).
8. La descarga, su motivo y su resultado se registran en la bitácora (C7).

V-I. Perspectiva forense de la bitácora

La bitácora es un control de trazabilidad y, a la vez, la principal fuente de evidencia que Custodia aportaría a una investigación. Cada registro responde a las preguntas básicas de un análisis forense: *quién* (cuenta de Windows autenticada), *cuándo* (fecha y hora), *qué* (tipo de operación), *sobre qué* (recurso) y *con qué resultado* (permitida o denegada). Se registran también los intentos rechazados, los bloqueos de cuenta y de pantalla, los códigos TOTP incorrectos junto a la operación que se intentaba y el motivo de cada copia exportada.

Ante un incidente, por ejemplo la sospecha de que un documento reservado fue consultado sin autorización, la bitácora permitiría, siguiendo las fases de NIST SP 800-86 [23]: (1) **recolectar** una copia de `audit.db` y calcular su resumen criptográfico antes de analizarla [24]; (2) **examinar** los registros filtrando por recurso, usuario, tipo de operación o intervalo de fechas, como permite el visor de la aplicación; (3) **analizar** la línea de tiempo, buscando intentos denegados, códigos incorrectos o cambios de permisos que indiquen reconocimiento o escalada; y (4) **reportar**, atribuyendo cada operación a una cuenta real de Windows. Los registros pueden contrastarse con el registro de eventos de seguridad de Windows y con las marcas de tiempo de NTFS; una operación que aparezca en una fuente y no en la otra es en sí misma un indicio de manipulación.

El valor probatorio de un registro depende de su integridad [22]. La ACL impide que un usuario estándar altere la bitácora, pero no un administrador del equipo (R7), y el encadenamiento de registros (C16) que haría detectable esa alteración, según el esquema de Schneier y Kelsey [25], no se implementó. Como el contenido de los archivos está cifrado, la bitácora es en la práctica la principal evidencia de lo ocurrido

Tabla IX
DISEÑO LÓGICO DE LOS CONTROLES DE SEGURIDAD Y SU ESTADO EN LA VERSIÓN FINAL

ID	Propiedad	Control	Mecanismo	Riesgos	Estado
C1	Autenticación	Verificación de identidad delegada al sistema operativo	Cuentas locales de Windows; `LogonUser` valida la contraseña y entrega un *token*. Custodia no almacena contraseñas. Solo entran miembros de `Custodia_Usuarios`.	R4, R12	Implementado
C2	Autenticación	Bloqueo por intentos fallidos	Bloqueo propio de 15 minutos tras 5 fallos en 10 minutos, con registro en un archivo restringido a Administradores y SYSTEM.	R4	Implementado
C3	Autorización	Decisión de acceso tomada por el núcleo de Windows	Cada operación se ejecuta bajo `ImpersonateLoggedOnUser`; NTFS evalúa la DACL del recurso contra el *token* del usuario.	R2, R10	Implementado
C4	Autorización	Mínimo privilegio por grupos y espacios	Raíz del almacén solo atravesable; espacio personal con herencia rota; carpeta compartida concedida al grupo.	R2, R11	Implementado
C5	Autorización	Confinamiento de rutas	Resolución canónica de cada ruta y rechazo si sale de la raíz, usa flujos alternativos de NTFS o nombres reservados de Windows.	R3	Implementado
C6	Autorización	Reversión garantizada de la suplantación	`RevertToSelf` en bloque `finally`; suplantación por hilo y concentrada en la clase `Sesion`.	R5	Implementado
C7	Trazabilidad	Registro de cada operación intentada	Bitácora SQLite con usuario, fecha y hora, operación, recurso y resultado; la escribe un hilo que nunca suplanta.	R7, R10, R12	Implementado
C8	Confidencialidad	Cifrado en reposo	AES-256-GCM por archivo mediante la biblioteca `cryptography` [39], con *nonce* aleatorio de 96 bits en cada escritura.	R1	Implementado
C9	Confidencialidad	Custodia de la clave maestra	DPAPI con entropía propia; ACL del archivo restringida a Administradores y SYSTEM; clave cargada en memoria antes de suplantar.	R1, R6	Implementado
C10	Integridad	Detección de manipulación	Etiqueta de autenticación GCM de 128 bits verificada en cada lectura.	R8	Implementado
C11	Integridad	Escritura atómica	Escritura en un temporal de la misma carpeta y renombrado final; una operación fallida no deja residuos.	R13	Implementado
C12	Integridad	Protección de la bitácora	ACL sobre `audit.db` que excluye a los usuarios estándar; el visor es de solo lectura.	R7	Implementado
C13	Disponibilidad	Respaldo de la clave maestra	Copia protegida de la clave y procedimiento documentado de recuperación.	R9	Pendiente
C14	Disponibilidad	Arranque verificado	Al iniciar se comprueban privilegios, almacén, clave y bitácora; en un equipo nuevo se preparan y se crea la primera cuenta administradora.	R9, R14	Implementado
C15	Confidencialidad	Cifrado de volumen	BitLocker con TPM en el equipo anfitrión.	R1, R6	Recomendación
C16	Integridad	Encadenamiento de la bitácora	Cada registro incluye el resumen SHA-256 del anterior; borrar o editar una entrada rompe la cadena.	R7, R12	No implementado
C17	Autenticación	Verificación en dos pasos	TOTP (RFC 6238) en el ingreso y como única puerta de toda operación sensible; cada código vale una vez por sesión; secretos protegidos con DPAPI.	R4, R10, R12, R15	Implementado
C18	Autenticación	Bloqueo por inactividad	Capa que tapa la ventana tras 5 minutos sin uso o con Ctrl+L; cierre de sesión y liberación del *token* tras 30 minutos más.	R15	Implementado
C19	Confidencialidad	Control de la exportación	Motivo obligatorio registrado en bitácora, código TOTP y límite de 20 copias cada 10 minutos por usuario.	R16	Implementado
C20	Confidencialidad	Cifrado por usuario	Clave de datos por archivo envuelta con RSA-2048-OAEP para cada persona autorizada; privada protegida con scrypt y la contraseña.	R6, R10	Implementado, desactivado por defecto
C21	Autorización	Salvaguardas de administración	Solo se gestionan cuentas de `Custodia_Usuarios`; las integradas se reconocen por su RID; nunca se retira al último administrador ni a uno mismo.	R10, R11	Implementado

con ellos [26]. La marca de tiempo proviene del reloj local, por lo que su exactitud depende de la configuración del equipo.

VI. DESCRIPCIÓN DE LA IMPLEMENTACIÓN

VI-A. Herramientas

La Tabla X resume las herramientas y la razón de cada elección. El código suma unas 11 400 líneas de Python (3 900 del núcleo, el resto de interfaz, pruebas y utilidades) y 5 800 líneas de QML.

VI-B. Arquitectura

La aplicación sigue la arquitectura de la Fig. 2. El núcleo (`src/custodia/core`) no depende de la interfaz y puede probarse sin ella. La interfaz (`src/custodia/gui`) dibuja en QML y decide en Python: las vistas solo avisan de lo que la persona hace a un objeto puente, y la clase `VentanaPrincipal` decide qué hacer, habla con la sesión y publica los datos que las vistas muestran.

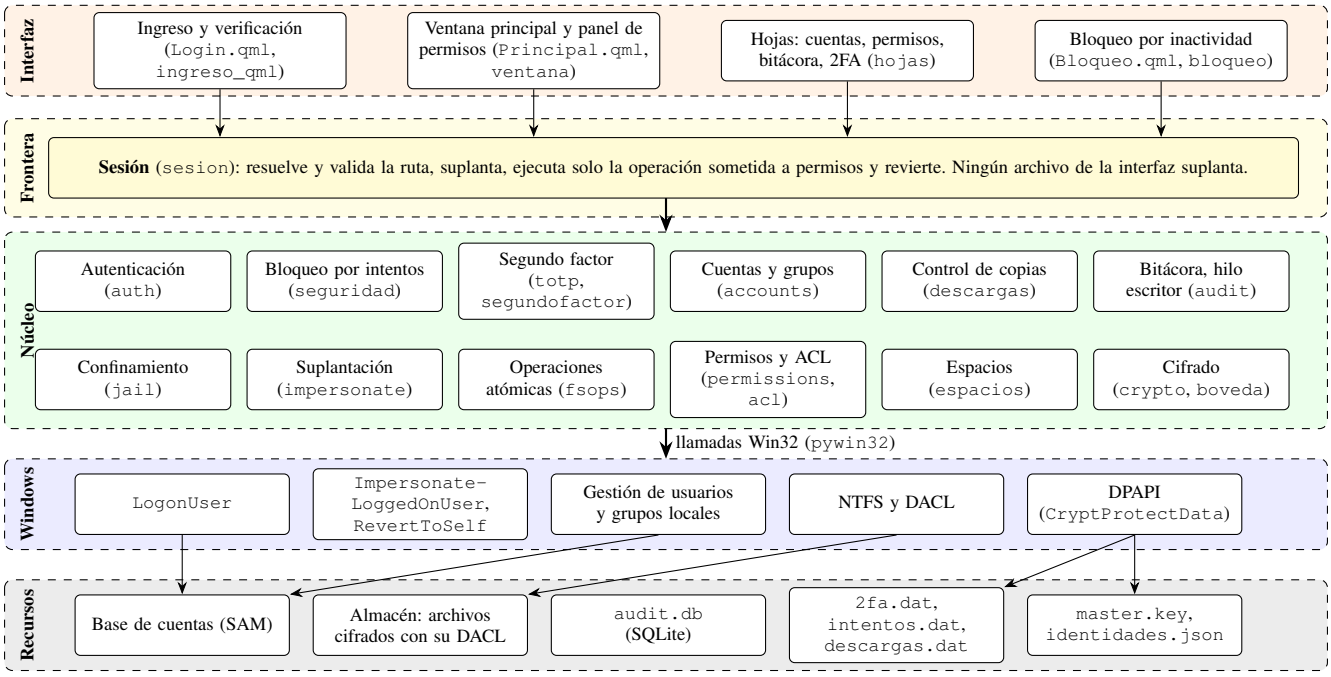


Figura 2. Diagrama lógico de la arquitectura por capas. Los archivos de estado de la capa de recursos llevan una ACL que solo admite a Administradores y SYSTEM.

Tabla X
HERRAMIENTAS DE LA IMPLEMENTACIÓN

Herramienta	**Uso y razón**
Python 3.12+	Lenguaje del núcleo y de la interfaz.
`pywin32` [40]	Acceso a la API de seguridad de Win32: `LogonUser`, suplantación, cuentas locales, DACL y DPAPI.
`cryptography` [39]	AES-256-GCM, RSA-OAEP y scrypt sobre OpenSSL, con implementación auditada.
PySide6, Qt Quick [34]	Interfaz nativa: vistas en QML y lógica en Python, sin navegador ni servidor local.
`segno` [41]	Código QR para dar de alta el segundo factor; se genera en el equipo, nunca en un servicio externo.
SQLite [33]	Bitácora: sin servidor ni credenciales que administrar.
`pytest`, `pytest-cov` [32]	Pruebas automatizadas sobre Windows real y medición de cobertura.
PyInstaller [35]	Ejecutable único con manifiesto `requireAdministrator`.

VI-C. Decisiones de implementación

- **La aplicación no evalúa permisos.** No existe ninguna condición que decida si un usuario puede leer un archivo: se adopta su identidad, se intenta la operación y, si Windows la rechaza, se traduce ese rechazo a un mensaje. Para mostrar los permisos efectivos sin intentar la operación, el módulo `permissions` sondea abriendo un manejador, lo que termina en el mismo motor de autorización de Windows; una prueba verifica que ambos caminos coincidan.
- **No se guardan contraseñas.** `LogonUser` las valida contra la SAM. No hay tabla de usuarios ni resúmenes de contraseñas que administrar o filtrar.
- **La bitácora se escribe fuera de la suplantación.** Registrar un evento solo lo encola; un hilo escritor que nunca suplanta vuelca la cola con los privilegios de la aplicación. Si el usuario suplantado pudiera escribir la bitácora, podría manipular el registro de sus propias acciones.
- **La clave maestra se carga antes de suplantar.** Solo Administradores y SYSTEM pueden leer su archivo, así que se carga al arrancar y, durante la suplantación, solo se consulta en memoria.
- **Escritura atómica.** El contenido va a un archivo temporal en la misma carpeta y se renombra al final; una operación denegada no deja archivos parciales.
- **Comprobaciones lentas en otro hilo.** `LogonUser` tarda a propósito cuando las credenciales fallan; el ingreso y el desbloqueo se comprueban en un hilo aparte para no congelar la interfaz.
- **Una sola puerta para las operaciones sensibles.** Eliminar, añadir, renombrar, exportar, cambiar permisos y administrar cuentas pasan por un único método que exige el código TOTP y registra el intento.

VI-D. Cambios respecto al diseño del Hito 2

- **Bloqueo por intentos propio (C2).** El diseño confiaba en la política de bloqueo de Windows, que suele estar desactivada fuera de un dominio y no cubre los códigos TOTP. Se implementó un bloqueo propio.
- **Controles nuevos (C17 a C21).** Verificación en dos pasos, bloqueo por inactividad, control de la exportación,

cifrado por usuario y salvaguardas de administración, con sus requisitos RF-09 a RF-13.

- **Cifrado por usuario opcional (C20).** Impide que un administrador sin la contraseña del dueño lea el contenido, pero restablecer la contraseña de una persona le hace perder el acceso a sus archivos. Por esa consecuencia se dejó desactivado por defecto.
- **Controles no implementados.** El respaldo de la clave (C13) y el encadenamiento de la bitácora (C16) quedaron fuera de la versión final.
- **Asimetría declarada.** Cambiar permisos lo autoriza Windows, porque se hace bajo suplantación y exige el derecho WRITE_DAC. Administrar cuentas, en cambio, lo autoriza la aplicación: crear una cuenta exige que el proceso esté elevado, sea quien sea el que inició sesión.

VII. Código fuente documentado

VII-A. Acceso al repositorio

El código fuente, las pruebas y este informe están publicados en el repositorio https://github.com/yanni2327/custodia [42]. El archivo `README.md` de la raíz explica la puesta en marcha, la estructura, las decisiones de arquitectura, la construcción del ejecutable y el estado de la verificación.

VII-B. Organización

- `src/custodia/core/`: núcleo. Un módulo por responsabilidad (Fig. 2); los dos *backends* de permisos, el real de Windows y uno en memoria para pruebas, en `backends/`.
- `src/custodia/gui/`: interfaz. Controladores en Python, vistas en `qml/` y recursos (tipografía e icono) en `recursos/`.
- `tests/`: dieciséis archivos de pruebas, uno por área.
- `scripts/`: inicialización para desarrollo (`bootstrap.py`), prueba de viabilidad de la suplantación, lanzador de la interfaz y generador del icono.
- `custodia.spec`: receta de empaquetado.

VII-C. Convenciones de documentación

Cada módulo comienza con una cadena de documentación que explica su responsabilidad y, sobre todo, *por qué* está hecho así: por ejemplo, por qué la bitácora es asíncrona o por qué el secreto TOTP usa DPAPI en ámbito de máquina. Los límites de cada mecanismo se declaran en el propio código bajo el título "alcance honesto". Toda la configuración está en `config.py` y puede cambiarse con variables de entorno, sin credenciales en el código.

VII-D. Construcción y ejecución

Desde una consola de Windows como administrador:

- Entorno: `py -m venv .venv` y `pip install -r requirements.txt`.
- Pruebas: `pytest`; cobertura con `pytest --cov=custodia.core`.
- Interfaz: `python scripts\custodia_gui.py`.
- Ejecutable, desde una consola sin elevar: `python -m PyInstaller custodia.spec`. Queda en `dist\Custodia.exe`.

VIII. Manual de usuario

VIII-A. Instalación y primer arranque

Custodia se distribuye como un único archivo, `Custodia.exe`, que no requiere instalar Python. Al abrirlo, Windows pide permiso para ejecutarlo como administrador; es necesario porque la aplicación administra cuentas y permisos. En un equipo donde nunca se ha usado, Custodia prepara sola el almacén, los grupos, la clave de cifrado y la bitácora, y pide crear la primera cuenta administradora. Cada arranque tarda unos segundos, porque el ejecutable se descomprime en una carpeta temporal.

VIII-B. Iniciar sesión

Escriba su usuario y contraseña de Windows y pulse **Entrar**. Solo pueden entrar las cuentas dadas de alta en Custodia. Si un administrador le asignó una contraseña temporal, la aplicación le pedirá crear una propia antes de continuar (pantalla **Crea tu contraseña**); debe tener al menos 8 caracteres, con letras y números. Si su cuenta tiene la verificación en dos pasos activada, escriba el código de 6 dígitos que muestra su aplicación de autenticación y pulse **Verificar**. Tras 5 intentos fallidos en 10 minutos la cuenta se bloquea 15 minutos (Fig. 3).

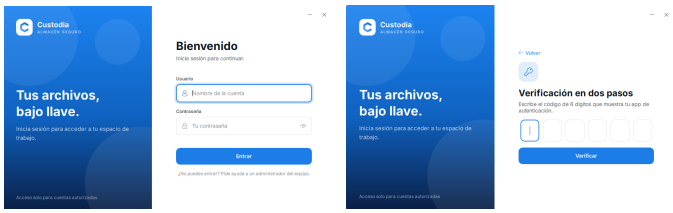


Figura 3. Inicio de sesión (izquierda) y verificación en dos pasos (derecha).

VIII-C. Activar la verificación en dos pasos

Es obligatoria para añadir, renombrar, eliminar o exportar archivos y para cambiar permisos. En el perfil (**Tu cuenta**), abra **Verificación en dos pasos** y pulse **Activar**. Escanee el código QR con una aplicación de autenticación del teléfono (Google Authenticator, Microsoft Authenticator u otra compatible), escriba el código que muestra y pulse **Confirmar y activar**. Si intenta una operación sensible sin haberla activado, Custodia le ofrecerá activarla en ese momento.

VIII-D. La ventana principal

A la izquierda, el panel **Carpetas** muestra su espacio personal y la carpeta compartida con su grupo; no verá las carpetas de otras personas. Un administrador ve el almacén completo. En el centro, el listado de la carpeta abierta con **Nombre**, **Tamaño** y **Modificado**, y el buscador **Buscar en esta carpeta**. Sobre el listado, el encabezado indica cuántos elementos hay y cuántos están cifrados. A la derecha, el panel del elemento seleccionado muestra su tipo, tamaño y si está

cifrado, su **Propietario** y, bajo **Lo que puedes hacer aquí**, sus permisos efectivos: las acciones permitidas aparecen marcadas y las denegadas tachadas. Debajo están las acciones **Guardar una copia…**, **Renombrar…** y **Permisos…**. El ícono de luna, arriba a la derecha, alterna entre tema claro y oscuro (Fig. 4).

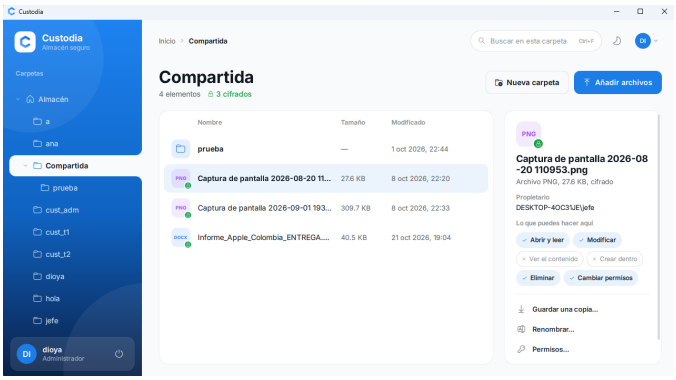


Figura 4. Ventana principal de un administrador: árbol de carpetas, listado con archivos cifrados y panel de permisos efectivos del archivo seleccionado.

VIII-E. Trabajar con archivos

- **Nueva carpeta**: crea una carpeta en la ubicación actual.
- **Añadir archivos**: guarda uno o varios archivos, cifrados. También puede arrastrarlos a la ventana.
- **Renombrar…** y **Eliminar**: actúan sobre el elemento seleccionado. Su carpeta personal y la compartida no se pueden renombrar ni eliminar.
- **Guardar una copia…**: exporta una copia legible fuera del almacén. Pide el motivo, que queda en la bitácora (Fig. 9), y un código de verificación. Se permiten 20 copias cada 10 minutos.

Añadir, renombrar, eliminar y guardar una copia piden un código de verificación. Cada código sirve una sola vez: si Custodia responde que ya se usó, espere a que su aplicación muestre uno nuevo (cambia cada 30 segundos). Los códigos incorrectos cuentan para el bloqueo de la cuenta.

VIII-F. Permisos

Seleccione un elemento y pulse **Permisos…**. La hoja **Quién tiene acceso** lista las cuentas y grupos con permiso, marcando las entradas **Heredado** (vienen de la carpeta superior y no se editan aquí) y las de tipo **Denegado**. En **Conceder un permiso** escriba la cuenta o el grupo en **A quién** y elija en **Qué puede hacer** una o varias opciones: **Abrir y leer**, **Modificar**, **Entrar y recorrer**, **Eliminar** o **Control total**. Active **Aplicar también a lo que contenga** para que las carpetas y archivos de dentro lo hereden, y pulse **Conceder**. Solo puede cambiar permisos si Windows se lo permite: los administradores y el propietario del elemento (Fig. 5).

VIII-G. Cuentas y grupos (administradores)

Desde **Cuentas y grupos** (Fig. 6) un administrador puede: crear una **Cuenta nueva**, activando **Puede administrar**

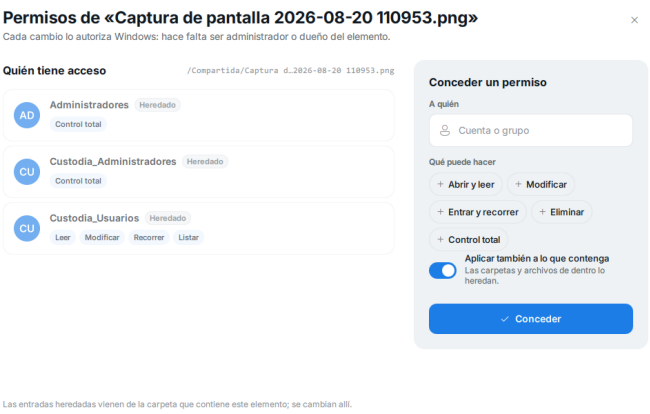


Figura 5. Hoja de permisos: entradas heredadas de la carpeta superior y formulario para conceder un permiso.

Custodia si la persona debe gestionar cuentas y consultar la bitácora; **Añadir una cuenta de Windows existente**; **Asignar a un grupo…** o **Quitar de un grupo…**; crear un **Nuevo grupo**; restablecer la contraseña de una persona que la olvidó, con una contraseña temporal que se muestra una sola vez; y restablecer la verificación en dos pasos de quien perdió el teléfono. Las cuentas creadas por Custodia se pueden eliminar; las que ya existían en Windows solo se pueden **Retirar de Custodia**, sin borrarlas del equipo. Nadie puede retirarse a sí mismo ni retirar al último administrador.

VIII-H. Bitácora (administradores)

La hoja **Bitácora de auditoría** (Fig. 7) muestra los eventos agrupados por día y permite buscar por usuario, recurso o detalle, y filtrar por **Usuario**, **Operación**, **Fecha** (con un calendario que marca los días con actividad) y por resultado: **Todos**, **Denegados** o **Permitidos**. Al elegir un evento se ven todos sus datos. Es de solo lectura: no hay forma de editar ni borrar registros desde la aplicación.

VIII-I. Bloqueo y cierre de sesión

Tras 5 minutos sin usar el ratón ni el teclado, o al pulsar Ctrl+L, la ventana se cubre con la pantalla de bloqueo, que muestra la hora y pide su contraseña (Fig. 8). Pulse **Desbloquear** para continuar o **Cerrar sesión** para salir. Si permanece bloqueada 30 minutos más, la sesión se cierra. La aplicación permite además cambiar la propia contraseña, alternar entre tema claro y oscuro y cerrar la sesión.

IX. Resultados y pruebas

IX-A. Estrategia de verificación

Las pruebas se ejecutan sobre Windows real, no sobre simulaciones: crean cuentas locales temporales, escriben ACL reales y las eliminan al terminar. La prueba central del proyecto (`test_el_kernel_deniega_el_acceso`) suplanta a una cuenta sin permisos e intenta leer un archivo; pasa solo si el rechazo lo emite el núcleo de Windows. Su contraparte comprueba que, al conceder el permiso, la misma operación funciona.

IX-B. Suite de pruebas

La suite tiene 112 funciones de prueba en dieciséis archivos; con los casos parametrizados suman 137 pruebas, de las cuales 136 pasan y una se omite (Tabla XI).

Tabla XI
PRUEBAS AUTOMATIZADAS POR ÁREA

Archivo	N.º	Qué verifica
`test_impersonation`	10	El núcleo deniega y permite; la identidad se restaura ante excepciones; hilos independientes.
`test_permissions`	10	Contrato `can()`; permisos efectivos; la consulta coincide con la operación real.
`test_jail`	10	Rutas fuera del almacén, flujos alternativos y nombres reservados.
`test_crypto`	10	Cifrado, *nonce* único, detección de manipulación, clave nunca en claro.
`test_accounts`	10	Cuentas y grupos; salvaguardas sobre cuentas ajenas e integradas.
`test_grupos_gui`	9	Grupos desde la interfaz; último administrador; registro en bitácora.
`test_confirmacion`	7	Código TOTP por operación, uso único y bloqueo por fallos.
`test_contrasenas`	7	Contraseñas temporales y cambio obligatorio.
`test_alcance`	6	Espacios personal y compartido; la raíz no se lista.
`test_boveda`	6	Cifrado por usuario: solo los destinatarios abren el archivo.
`test_totp`	6	Vector oficial de la RFC 6238 y tolerancia de reloj.
`test_audit`	5	Secuencia de RF-05; el usuario registrado es el suplantado.
`test_descargas`	5	Límite de copias por usuario.
`test_seguridad`	5	Bloqueo por intentos; mayúsculas no lo evaden.
`test_rnf`	4	Mediciones de RNF-01, RNF-02 y RNF-05.
`test_ingreso_miembros`	2	Solo entran cuentas de Custodia.

IX-C. Requisitos funcionales

Los trece requisitos funcionales están implementados. Todos excepto RF-11 tienen al menos una prueba automatizada que los verifica (Tabla XI): RF-01 y RF-02 en `test_accounts` y `test_grupos_gui`; RF-03 en `test_impersonation`; RF-04 en `test_jail`; RF-05 en `test_audit`; RF-06 y RF-07 en `test_permissions`; RF-08 en `test_crypto`; RF-09 en `test_totp` y `test_confirmacion`; RF-10 en `test_seguridad`; RF-12 en `test_descargas` y `test_confirmacion`; y RF-13 en `test_alcance`. El bloqueo por inactividad (RF-11) depende de eventos de la interfaz y no tiene prueba automatizada.

IX-D. Requisitos no funcionales

La Tabla XII presenta las mediciones. Se cumplen seis de los ocho requisitos; RNF-06 no se cumple y RNF-04 queda pendiente.

Tabla XII
RESULTADOS DE LOS REQUISITOS NO FUNCIONALES

ID	Criterio	Resultado	Estado
RNF-01	0 suplantaciones remanentes en 100 operaciones	0	Cumple
RNF-02	$\leq$ 500 ms por 10 MB	49,5 ms	Cumple
RNF-03	Mismas pruebas en ambos *backends*	Pasan	Cumple
RNF-04	$\leq$ 3 pasos, 2 personas	Sin realizar	Pendiente
RNF-05	0 archivos parciales en 50 denegaciones	0	Cumple
RNF-06	Cobertura $\geq$ 80 %	73 %	No cumple
RNF-07	Ejecutable único sin Python	Construido (170 MB); falta probarlo en equipo limpio	Cumple en parte
RNF-08	Sobrecarga $\leq$ 200 ms; clave no en claro	14,8 ms; clave no aparece	Cumple

IX-E. Vectores de ataque

La Tabla XIII contrasta cada vector con la evidencia obtenida.

X. CONCLUSIONES Y RECOMENDACIONES

X-A. Conclusiones

- **Los tres objetivos específicos se cumplieron.** Los archivos se cifran con AES-256-GCM; la autorización la decide Windows, y una prueba sobre el sistema real lo demuestra; y cada operación intentada queda en una bitácora que el usuario auditado no puede alterar.
- **Delegar la autorización eliminó el riesgo más alto del caso.** El acceso de un usuario a archivos ajenos pasó de crítico a bajo sin escribir una sola regla de permisos en la aplicación.
- **La implementación reveló riesgos que el diseño no veía.** La sesión desatendida y la exportación de copias legibles (R15, R16) aparecieron al usar la aplicación, no en el papel, y motivaron cinco requisitos nuevos. El análisis de riesgos resultó ser un proceso continuo y no un entregable cerrado.
- **El rendimiento no fue una restricción.** Suplantar y cifrar en cada operación cuesta decenas de milisegundos, un orden de magnitud por debajo de los límites fijados.
- **Quedan tres riesgos altos.** Dos son inherentes a un diseño local (R1, R6) y uno se debe a un control no implementado (R9).

X-B. Recomendaciones

1. Implementar el respaldo de la clave maestra y su procedimiento de recuperación [13] antes de cualquier uso

Tabla XIII
RESULTADO FRENTE A LOS VECTORES DE ATAQUE

ID	Evidencia	Resultado
V1	Bloqueo al alcanzar el umbral, también con mayúsculas cambiadas (`test_seguridad`).	Mitigado
V2	Rutas con `..`, flujos alternativos y nombres reservados rechazadas (`test_jail`).	Mitigado
V3	El núcleo deniega sin ACE; la raíz no se enumera (`test_impersonation`, `test_alcance`).	Mitigado
V4	Identidad restaurada ante excepciones y en 100 operaciones (`test_rnf`).	Mitigado
V5	El archivo en disco no es legible (`test_crypto`); el disco completo sigue expuesto (R1).	Mitigado en parte
V6	La clave no está en claro en disco; un administrador local puede pedirla a DPAPI (R6).	Riesgo aceptado
V7	Un byte alterado hace fallar el descifrado (`test_crypto`).	Mitigado
V8	El usuario suplantado no escribe la bitácora (`test_audit`); un administrador sí puede (R7).	Mitigado en parte
V9	Sin respaldo de la clave (C13).	No mitigado
V10	Sin servicio de red; no se probó un ataque de carga de bibliotecas.	Sin prueba
V11	Código TOTP por operación y de uso único (`test_confirmacion`); bloqueo por inactividad sin prueba automatizada.	Mitigado
V12	Límite de copias por usuario (`test_descargas`).	Mitigado

con información real: es el único riesgo alto que depende de trabajo pendiente.

2. Desplegar el equipo anfitrión con BitLocker y TPM para cubrir el robo del disco completo (R1).
3. Subir la cobertura del núcleo al 80 % y realizar la prueba de usabilidad con dos personas ajenas al desarrollo.
4. Probar el ejecutable en un equipo limpio y reducir su tamaño excluyendo los módulos de Qt que no se usan.
5. Encadenar los registros de la bitácora con SHA-256 (C16) y sincronizar el reloj del equipo, para que la bitácora sostenga valor probatorio.
6. Evaluar con usuarios el cifrado por usuario (C20): reduce el riesgo frente a administradores, pero exige un procedimiento para no perder archivos al restablecer contraseñas.
7. Si se despliega con datos personales reales, documentar el tratamiento conforme a la Ley 1581 de 2012.

REFERENCIAS

[1] National Institute of Standards and Technology, *Advanced Encryption Standard (AES)*, FIPS PUB 197, nov. 2001.

[2] Microsoft, "Access control lists," Microsoft Learn. [En línea]. Disponible: https://learn.microsoft.com/windows/win32/secauthz/access-control-lists (accedido: 6 nov. 2026).

[3] Microsoft, "ImpersonateLoggedOnUser function (securitybaseapi.h)," Microsoft Learn. [En línea]. Disponible: https://learn.microsoft.com/windows/win32/api/securitybaseapi/nf-securitybaseapi-impersonateloggedonuser (accedido: 6 nov. 2026).

[4] J. H. Saltzer y M. D. Schroeder, "The protection of information in computer systems," *Proc. IEEE*, vol. 63, n.º 9, pp. 1278–1308, sep. 1975, doi: 10.1109/PROC.1975.9939.

[5] R. S. Sandhu y P. Samarati, "Access control: Principle and practice," *IEEE Commun. Mag.*, vol. 32, n.º 9, pp. 40–48, sep. 1994, doi: 10.1109/35.312842.

[6] B. W. Lampson, "Protection," *ACM SIGOPS Oper. Syst. Rev.*, vol. 8, n.º 1, pp. 18–24, ene. 1974.

[7] P. Yosifovich, A. Ionescu, M. E. Russinovich y D. A. Solomon, *Windows Internals, Part 1*, 7.ª ed. Redmond, WA, USA: Microsoft Press, 2017.

[8] Microsoft, "LogonUserW function (winbase.h)," Microsoft Learn. [En línea]. Disponible: https://learn.microsoft.com/windows/win32/api/winbase/nf-winbase-logonuserw (accedido: 6 nov. 2026).

[9] J. Daemen y V. Rijmen, *The Design of Rijndael: AES — The Advanced Encryption Standard*. Berlín, Alemania: Springer, 2002.

[10] M. Dworkin, *Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC*, NIST Special Publication 800-38D, nov. 2007.

[11] D. A. McGrew y J. Viega, "The security and performance of the Galois/Counter Mode (GCM) of operation," en *Progress in Cryptology – INDOCRYPT 2004*, ser. LNCS, vol. 3348. Berlín, Alemania: Springer, 2004, pp. 343–355, doi: 10.1007/978-3-540-30556-9_27.

[12] Microsoft, "CryptProtectData function (dpapi.h)," Microsoft Learn. [En línea]. Disponible: https://learn.microsoft.com/windows/win32/api/dpapi/nf-dpapi-cryptprotectdata (accedido: 6 nov. 2026).

[13] E. Barker, *Recommendation for Key Management: Part 1 – General*, NIST Special Publication 800-57 Part 1 Rev. 5, may. 2020.

[14] K. Moriarty, B. Kaliski, J. Jonsson y A. Rusch, "PKCS #1: RSA Cryptography Specifications Version 2.2," IETF, RFC 8017, nov. 2016.

[15] C. Percival y S. Josefsson, "The scrypt Password-Based Key Derivation Function," IETF, RFC 7914, ago. 2016.

[16] J. Bonneau, C. Herley, P. C. van Oorschot y F. Stajano, "The quest to replace passwords: A framework for comparative evaluation of web authentication schemes," en *Proc. IEEE Symp. Security and Privacy*, San Francisco, CA, USA, 2012, pp. 553–567, doi: 10.1109/SP.2012.44.

[17] A. Ometov, S. Bezzateev, N. Mäkitalo, S. Andreev, T. Mikkonen y Y. Koucheryavy, "Multi-factor authentication: A survey," *Cryptography*, vol. 2, n.º 1, art. 1, ene. 2018, doi: 10.3390/cryptography2010001.

[18] D. M'Raihi, M. Bellare, F. Hoornaert, D. Naccache y O. Ranen, "HOTP: An HMAC-Based One-Time Password Algorithm," IETF, RFC 4226, dic. 2005.

[19] D. M'Raihi, S. Machani, M. Pei y J. Rydell, "TOTP: Time-Based One-Time Password Algorithm," IETF, RFC 6238, may. 2011.

[20] P. A. Grassi *et al.*, *Digital Identity Guidelines: Authentication and Lifecycle Management*, NIST Special Publication 800-63B, jun. 2017.

[21] *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*, ISO/IEC 27001:2022.

[22] K. Kent y M. Souppaya, *Guide to Computer Security Log Management*, NIST Special Publication 800-92, sep. 2006.

[23] K. Kent, S. Chevalier, T. Grance y H. Dang, *Guide to Integrating Forensic Techniques into Incident Response*, NIST Special Publication 800-86, ago. 2006.

[24] *Information technology — Security techniques — Guidelines for identification, collection, acquisition and preservation of digital evidence*, ISO/IEC 27037:2012.

[25] B. Schneier y J. Kelsey, "Secure audit logs to support computer forensics," *ACM Trans. Inf. Syst. Secur.*, vol. 2, n.º 2, pp. 159–176, may. 1999, doi: 10.1145/317087.317089.

[26] S. L. Garfinkel, "Digital forensics research: The next 10 years," *Digit. Investig.*, vol. 7, pp. S64–S73, ago. 2010, doi: 10.1016/j.diin.2010.05.009.

[27] Ministerio de Hacienda y Administraciones Públicas, *MAGERIT versión 3.0: Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro I: Método*. Madrid, España, 2012.

[28] Ministerio de Hacienda y Administraciones Públicas, *MAGERIT versión 3.0. Libro II: Catálogo de Elementos*. Madrid, España, 2012.

[29] *Information security, cybersecurity and privacy protection — Guidance on managing information security risks*, ISO/IEC 27005:2022.

[30] Congreso de la República de Colombia, “Ley Estatutaria 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales,” *Diario Oficial*, n.º 48.587, 18 oct. 2012.
[31] Congreso de la República de Colombia, “Ley 1273 de 2009, por medio de la cual se modifica el Código Penal, se crea un nuevo bien jurídico tutelado denominado ‘de la protección de la información y de los datos’,” *Diario Oficial*, n.º 47.223, 5 ene. 2009.
[32] pytest-cov contributors, “pytest-cov documentation.” [En línea]. Disponible: https://pytest-cov.readthedocs.io (accedido: 6 nov. 2026).
[33] SQLite Consortium, “SQLite documentation.” [En línea]. Disponible: https://www.sqlite.org/docs.html (accedido: 6 nov. 2026).
[34] The Qt Company, “Qt for Python documentation.” [En línea]. Disponible: https://doc.qt.io/qtforpython-6/ (accedido: 6 nov. 2026).
[35] PyInstaller Development Team, “PyInstaller manual.” [En línea]. Disponible: https://pyinstaller.org (accedido: 6 nov. 2026).
[36] A. Shostack, *Threat Modeling: Designing for Security*. Indianapolis, IN, USA: Wiley, 2014.
[37] The MITRE Corporation, “MITRE ATT&CK.” [En línea]. Disponible: https://attack.mitre.org (accedido: 6 nov. 2026).
[38] The MITRE Corporation, “Common Weakness Enumeration (CWE).” [En línea]. Disponible: https://cwe.mitre.org (accedido: 6 nov. 2026).
[39] Python Cryptographic Authority, “cryptography documentation.” [En línea]. Disponible: https://cryptography.io (accedido: 6 nov. 2026).
[40] M. Hammond *et al.*, “pywin32: Python for Windows Extensions.” [En línea]. Disponible: https://github.com/mhammond/pywin32 (accedido: 6 nov. 2026).
[41] L. Heuer, “Segno: Python QR Code and Micro QR Code encoder.” [En línea]. Disponible: https://segno.readthedocs.io (accedido: 6 nov. 2026).
[42] D. Y. Aranguren Sanabria y P. A. Quintana Barrera, “Custodia: código fuente,” GitHub, 2026. [En línea]. Disponible: https://github.com/yanni2327/custodia

ANEXO A
COMANDOS DE VERIFICACIÓN

Cualquier auditor puede comprobar con herramientas de Windows, sin pasar por Custodia, que los controles son reales. Desde una consola como administrador:

- `net localgroup Custodia_Usuarios`: cuentas dadas de alta en la aplicación.
- `net user <cuenta>`: grupos y estado de una cuenta.
- `icacls C:\ProgramData\Custodia\storage`: permisos de la raíz del almacén, que para los usuarios solo deben permitir atravesarla.
- `icacls C:\ProgramData\Custodia\master.key`: acceso limitado a Administradores y SYSTEM.
- Abrir cualquier archivo del almacén con un editor de texto: debe empezar con `CUSTODIA` seguido de contenido ilegible.

ANEXO B
MATRIZ DE TRAZABILIDAD

La Tabla XIV relaciona cada requisito funcional con los controles que lo implementan (Tabla IX) y con las pruebas automatizadas que lo verifican (Tabla XI). Permite comprobar que ningún requisito queda sin control y señala el único que carece de prueba automatizada.

ANEXO C
CAPTURAS DE PANTALLA

Las Figs. 6 a 9 complementan las del manual de usuario (Sección VIII). Se tomaron con cuentas de prueba creadas por las autoras.

Tabla XIV
TRAZABILIDAD ENTRE REQUISITOS, CONTROLES Y PRUEBAS

Req.	**Controles**	**Pruebas**
RF-01	C1, C21	`test_accounts`
RF-02	C4, C21	`test_accounts`, `test_grupos_gui`
RF-03	C3, C6, C11	`test_impersonation`, `test_rnf`
RF-04	C5	`test_jail`
RF-05	C7, C12	`test_audit`
RF-06	C3	`test_permissions`
RF-07	C3	`test_permissions`
RF-08	C8, C9, C10	`test_crypto`
RF-09	C17	`test_totp`, `test_confirmacion`
RF-10	C2	`test_seguridad`
RF-11	C18	Sin prueba automatizada
RF-12	C19	`test_descargas`, `test_confirmacion`
RF-13	C4	`test_alcance`

ANEXO D
CRONOLOGÍA DE LA IMPLEMENTACIÓN

La Tabla XV reconstruye las etapas a partir de la fecha de última modificación de los archivos del proyecto.

Tabla XV
ETAPAS DE LA IMPLEMENTACIÓN

Fecha	**Trabajo**
8 oct. 2026	Núcleo: suplantación, cuentas, ACL, confinamiento, permisos, cifrado y bitácora, con sus pruebas.
20 oct. 2026	Bloqueo por intentos, control de copias y cifrado por usuario.
21–22 oct. 2026	Espacios personal y compartido; nueva pantalla de ingreso.
5 nov. 2026	Interfaz completa en QML; verificación en dos pasos y confirmación de operaciones; contraseñas temporales; gestión de grupos; bloqueo por inactividad.
6 nov. 2026	Icono, receta de empaquetado, ejecutable `Custodia.exe` y documentación.

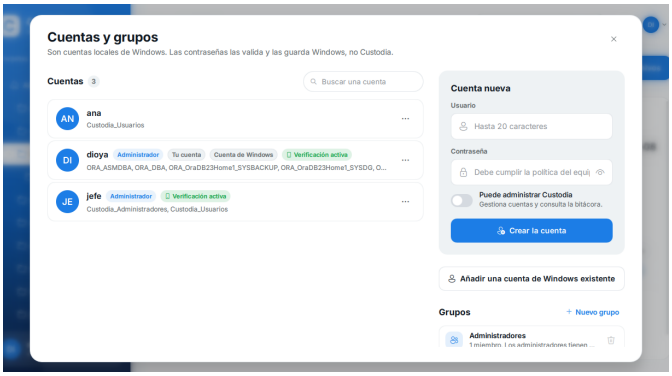


Figura 6. Hoja de cuentas y grupos. Cada cuenta indica su rol, si es una cuenta de Windows incorporada y si tiene la verificación en dos pasos activa.

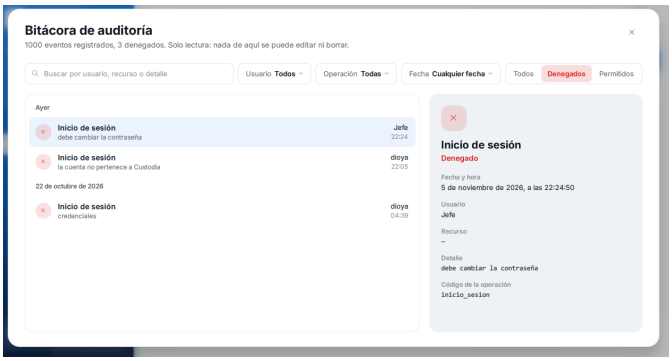


Figura 7. Bitácora de auditoría filtrada por eventos denegados, con el detalle de un inicio de sesión rechazado porque la cuenta debía cambiar su contraseña.

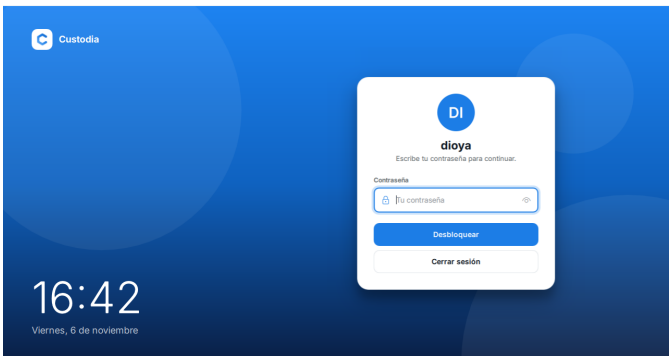


Figura 8. Pantalla de bloqueo por inactividad.

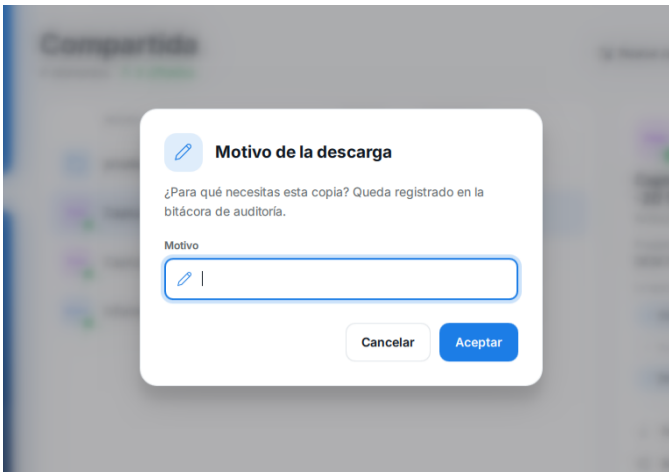


Figura 9. Motivo obligatorio antes de exportar una copia; queda registrado en la bitácora.